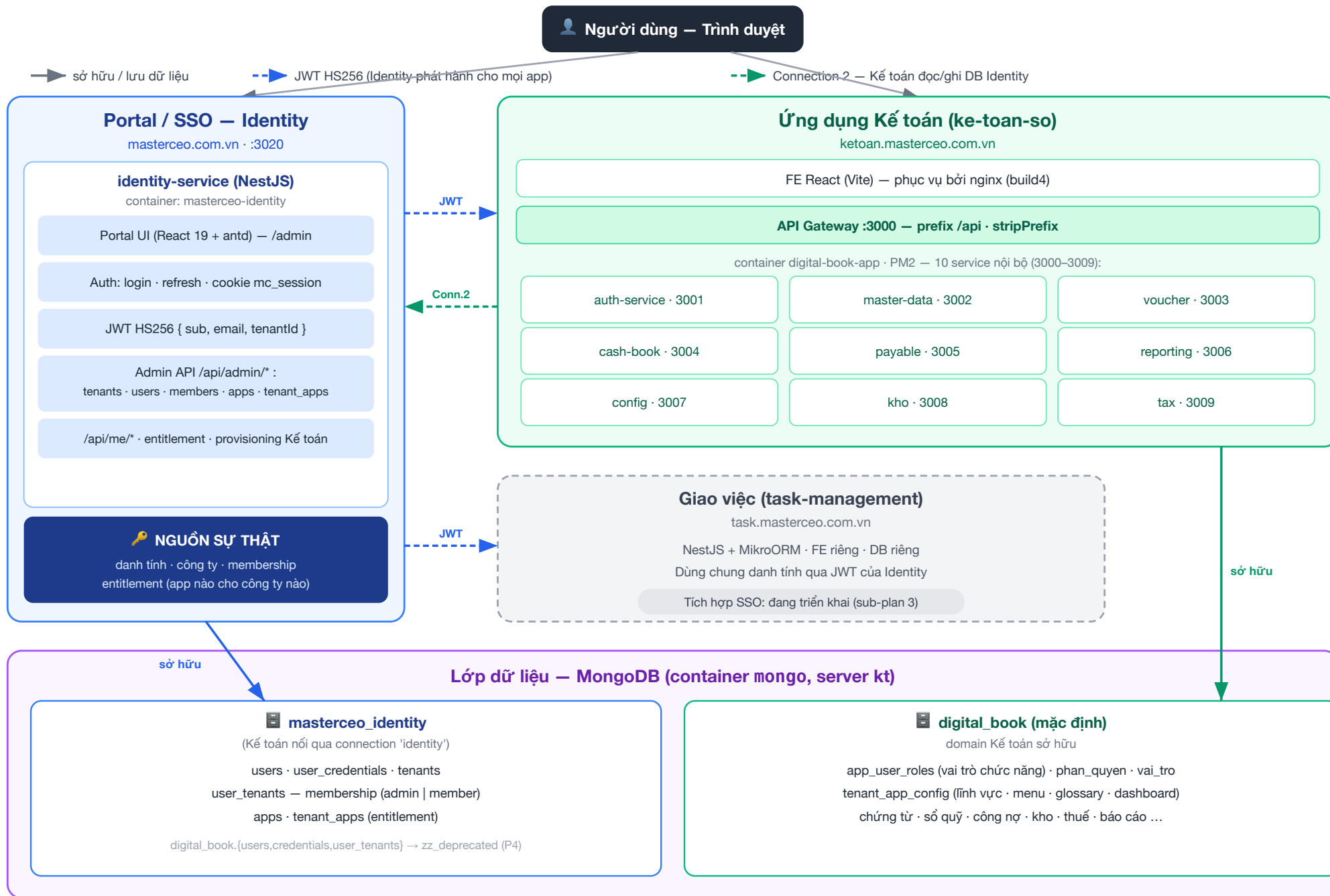


Kiến trúc hệ thống — Nền tảng ERP MasterCeo

Đăng nhập một lần (SSO) · danh tính chung · phân quyền riêng từng ứng dụng



Luồng đăng nhập SSO & Nguyên tắc sở hữu dữ liệu

① Luồng đăng nhập một lần (SSO)

1 · Đăng nhập tại Portal

Người dùng vào masterceo.com.vn → nhập email + mật khẩu.

2 · Identity xác thực

Đặt cookie mc_session (httpOnly). Trả danh sách App của user — đã lọc theo entitlement tenant_apps.

3 · Chọn App & Công ty

Người dùng chọn “Kế toán” → chọn công ty (tenant).

4 · Portal điều hướng

Redirect → ketoan.masterceo.com.vn?tenant=<id>.

5 · Kế toán nhận phiên (ssoHandoff)

FE đọc ?tenant → POST identity /api/refresh {tenantId}
(kèm cookie) → nhận access token JWT {sub,email,tenantId}.

6 · Nạp phân quyền (BE Kế toán)

JwtGuard + AuthzLoader nạp vai trò & quyền từ app_user_roles + phan_quyen theo (userId, tenantId).

7 · Vào ứng dụng — không đăng nhập lại

Đổi công ty bất kỳ lúc nào qua /switch-tenant.

② Danh tính chung — Phân quyền riêng

Sở hữu theo domain — “ai quản” là quy tắc riêng

Identity (SSO) sở hữu

- users · credentials
- tenants (định danh công ty)
- memberships
role = admin | member
- apps
- tenant_apps
entitlement: công ty ↔ app

Quản trị: superAdmin (theo email);
entitlement chỉ superAdmin cấp.

App Kế toán sở hữu

- app_user_roles
vai trò chức năng
- phan_quyen · vai_tro
- tenant_app_config
lĩnh vực · menu · glossary
- dữ liệu nghiệp vụ
chứng từ · sổ quỹ · công nợ ...

Quản trị: Admin công ty
(membership.role = admin).

⚠ Hai nghĩa “admin” — đừng nhầm

- Identity: **user_tenants.role = admin | member** — cấp thành viên/quản trị công ty.
- Kế toán: **vai trò chức năng 'Admin'** trong phan_quyen — quyết định quyền màn hình.
→ Một người có thể là admin (membership) nhưng vai trò chức năng do app cấp riêng.

③ Công nghệ & triển khai

- FE Kế toán: React 18 · Vite · antd + shadcn/ui · mẫu CHanIdler (RxJS).
- BE Kế toán: NestJS 11 · microservices · MongoDB (TypeORM).
- Identity: NestJS · TypeORM/Mongo · Portal React 19 + antd (phục vụ /api + tĩnh).
- Bảo mật: JWT HS256 thống nhất (cùng JWT_SECRET) · cookie mc_session (refresh).
- Hạ tầng: Docker — digital-book-app (PM2), masterceo-identity · nginx · server “kt”.
- Gateway: prefix /api + stripPrefix → định tuyến tới 9 service nội bộ.

Nguyên tắc: «Đăng nhập một lần ở Portal → chọn App → chọn Công ty → vào thẳng ứng dụng»

Các app trao đổi dữ liệu liên-app (vd Kế toán → báo cáo nhân sự bên Giao việc) — lộ trình GD2 (outbox/event).